posture, mandatory authentication levels, restrictions on sensitive activities, and conditions for break-glass access. These policies capture decisions that traditionally appeared in security handbooks, architecture checklists, or informal norms, making them concrete and integrating those decisions into the real-time authorization process.

This approach provided ACME with two key advantages. First, it enabled the security and identity teams to specify enterprise-wide requirements without interfering with the independence of application teams, who continued to manage their own policies for business logic and resource-specific rules. Second, it prevented the creation of another standalone security mechanism. Zero Trust became a natural extension of ACME's existing PBAC foundation rather than yet another system sitting off to the side.

What changed for application teams was how they tested and validated their own policies. Because every access request is evaluated against both foundational security policies and application-specific rules, teams needed to ensure their policies behaved correctly in the presence of those broader controls. Testing now included verifying that their application logic continued to work when device posture was absent, when authentication sessions were expired, or when environmental context triggered an enterprise-wide restriction. This shift wasn't burdensome, but it did require teams to adopt a more comprehensive testing model that accounted for the full zero-trust security architecture rather than testing their policies in isolation.

By grounding Zero Trust in authorization—expressed through clear, governable policies—ACME found a way to move past vague slogans and vendor promises. Zero Trust became tangible: a method for making better access decisions, applied consistently and adaptable to the organization's risk tolerance. The next section examines how ACME directly expresses these core ideas in policy and how those policies interact with application and engineering rules to create a cohesive zero-trust security architecture.